Ethical Hacking and Incident Response
CT080-3-2 (Version VE1)

01: Introduction to Ethical Hacking

Topic & Structure of The Lesson

- Information Security Overview
- Cyber Kill Chain Concepts
- Hacking Concepts
- Ethical Hacking Concepts
- Information Security Controls

Learning Outcomes

- **At the end of this topic, You should be able to**
  1. Describe the elements in information security
  2. Explain information security attacks
  3. Describe cyber kill chain methodology, TTPs and IoCs
  4. Describe hacking concepts, types and phases
  5. Explain ethical hacking concepts and scope
  6. Understand information security controls (defense-in-depth, risk management, cyber threat intelligence, threat modeling, and incident management process)

Key Terms

If you have mastered this topic, you should be able to use the following terms correctly in your assignments and exams:

- Cyber security
- Confidentiality
- Integrity
- Availability
- Non-repudiation
- Cyber Kill Chain
- Hacking
- Hacker

1. Information Security Overview

1. Information Security Overview
2. Cyber Kill Chain Concepts
3. Hacking Concepts
4. Ethical Hacking Concepts
5. Information Security Controls

Element of Information Security

Information security is a state of well-being of information and infrastructure in which the possibility of **theft**, **tampering**, and **disruption of information and services** is low or tolerable

Confidentiality	Assurance that the information is accessible only to those **authorized to have access**
Integrity	The **trustworthiness of data or resources** in terms of preventing improper or unauthorized changes
Availability	Assurance that the systems responsible for delivering, storing, and processing information are accessible when **required by the authorized users**
Authenticity	Refers to the characteristic of a communication, document, or any data that ensures the **quality of being genuine**
Non-Repudiation	A **guarantee** that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message

Information Security Attacks

Attacks = Motive (Goal) + Method + Vulnerability

- A motive originates out of the notion that the **target system stores or processes** something valuable, and this leads to the threat of an attack on the system
- Attackers try various tools and attack techniques to **exploit vulnerabilities** in a computer system or its security policy and controls in order to fulfil their motives

Motives behind information security attacks

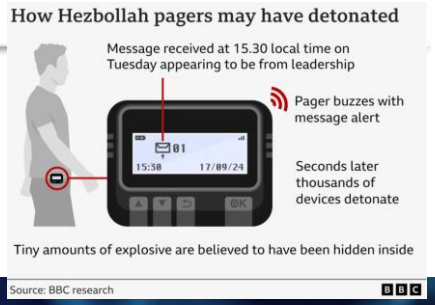
- Disrupting business continuity
- Stealing information and manipulating data
- Creating fear and chaos by disrupting critical infrastructures
- Causing financial loss to the target
- Propagating religious or political beliefs
- Achieving a state's military objectives
- Damaging the reputation of the target
- Taking revenge
- Demanding ransom

Classification of Attacks

Passive Attacks	• Passive attacks do not tamper with the data and involve intercepting and **monitoring network traffic** and data flow on the target network • Examples include sniffing and eavesdropping
Active Attacks	• Active attacks tamper with the data in transit or **disrupt the communication** or services between the systems to bypass or break into secured systems • Examples include DoS, Man-in-the-Middle, session hijacking, and SQL injection
Close-in Attacks	• Close-in attacks are performed when the attacker is in close physical proximity with the target system or network in order to gather, modify, or **disrupt access** to information • Examples include social engineering such as eavesdropping, shoulder surfing, and dumpster diving
Insider Attacks	• Insider attacks involve using privileged access to **violate rules** or intentionally cause a threat to the organization's information or information systems • Examples include theft of physical devices and planting keyloggers, backdoors, and malware
Distribution Attacks	• Distribution attacks occur when attackers **tamper with hardware** or **software** prior to installation • Attackers tamper with the hardware or software at its source or in transit

At least 32 people, including two children, were killed and thousands more injured, many seriously, after communication devices, some used by the armed group Hezbollah, dramatically exploded across Lebanon on Tuesday and Wednesday.

In the latest round of blasts on Wednesday, exploding walkie-talkies killed 20 and injured at least 450 people, according to Lebanon's health ministry.



2. Cyber Kill Chain Concepts

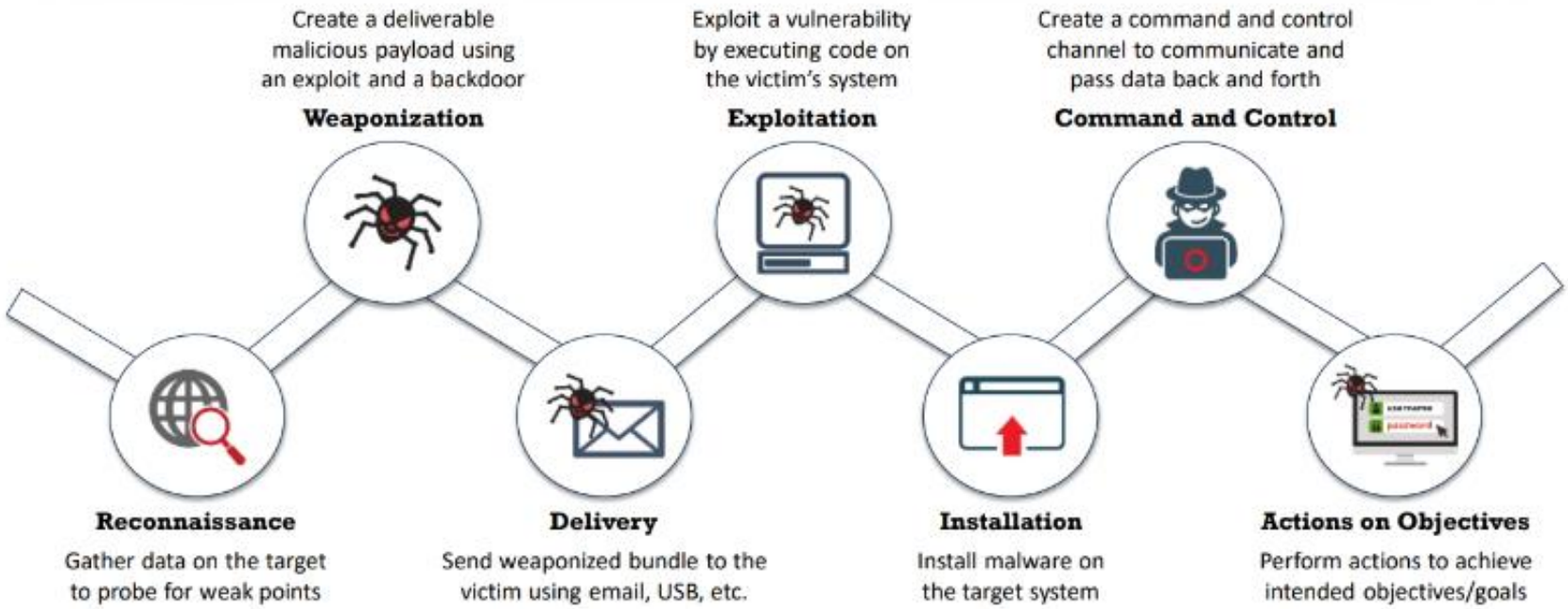
1. Information Security Overview
2. Cyber Kill Chain Concepts
3. Hacking Concepts
4. Ethical Hacking Concepts
5. Information Security Controls

Cyber Kill Chain Concepts

- **Security framework** developed by Lockheed Martin to describe **stages of a cyberattack** and **how defenders can detect & stop it**.
- Helps organizations **understand the various possible threats** at every stage of an attack and the necessary countermeasures to defend against such attacks.
- Provides security professionals with a clear insight into the attack strategy used by the adversary so that different levels of security controls can be implemented to protect the IT infrastructure of the organization.

Cyber Kill Chain Methodology

- The cyber kill chain methodology is a component of intelligence-driven defense for the identification and **prevention of malicious intrusion activities**
- It provides greater insight into attack phases, which helps security professionals to understand the **adversary's tactics, techniques, and procedures beforehand**



* Further reading activity

Reconnaissance

An adversary performs reconnaissance to collect as much information about the target as possible to probe for weak points before attacking. They look for information such as publicly available information on the Internet, network information, system information, and the organizational information of the target. By conducting reconnaissance across different network levels, the adversary can gain information such as network blocks, specific IP addresses, and employee details. The adversary may use automated tools such as open ports and services, vulnerabilities in applications, and login credentials, to obtain information. Such information can help the adversary in gaining backdoor access to the target network.

Activities of the adversary include the following:

- Gathering information about the target organization by searching the Internet or through social engineering
- Performing analysis of various online activities and publicly available information
- Gathering information from social networking sites and web services
- Obtaining information about websites visited
- Monitoring and analyzing the target organization's website
- Performing Whois, DNS, and network footprinting
- Performing scanning to identify open ports and services

Weaponization

The adversary analyzes the data collected in the previous stage to identify the vulnerabilities and techniques that can exploit and gain unauthorized access to the target organization. Based on the vulnerabilities identified during analysis, the adversary selects or creates a tailored deliverable malicious payload (remote-access malware weapon) using an exploit and a backdoor to send it to the victim. An adversary may target specific network devices, operating systems, endpoint devices, or even individuals within the organization to carry out their attack. For example, the adversary may send a phishing email to an employee of the target organization, which may include a malicious attachment such as a virus or worm that, when downloaded, installs a backdoor on the system that allows remote access to the adversary.

The following are the activities of the adversary:

- Identifying appropriate malware payload based on the analysis
- Creating a new malware payload or selecting, reusing, modifying the available malware payloads based on the identified vulnerability
- Creating a phishing email campaign o Leveraging exploit kits and botnets

Delivery

The previous stage included creating a weapon. Its payload is transmitted to the intended victim(s) as an email attachment, via a malicious link on websites, or through a vulnerable web application or USB drive. Delivery is a key stage that measures the effectiveness of the defense strategies implemented by the target organization based on whether the intrusion attempt of the adversary is blocked or not.

The following are the activities of the adversary:

- Sending phishing emails to employees of the target organization
- Distributing USB drives containing malicious payload to employees of the target organization
- Performing attacks such as watering hole on the compromised website
- Implementing various hacking tools against the operating systems, applications, and servers of the target organization

Exploitation

After the weapon is transmitted to the intended victim, exploitation triggers the adversary's malicious code to exploit a vulnerability in the operating system, application, or server on a target system. At this stage, the organization may face threats such as authentication and authorization attacks, arbitrary code execution, physical security threats, and security misconfiguration.

Activities of the adversary include the following:

Exploiting software or hardware vulnerabilities to gain remote access to the target system

Installation

The adversary downloads and installs more malicious software on the target system to maintain access to the target network for an extended period. They may use the weapon to install a backdoor to gain remote access. After the injection of the malicious code on one target system, the adversary gains the capability to spread the infection to other end systems in the network. Also, the adversary tries to hide the presence of malicious activities from security controls like firewalls using various techniques such as encryption.

The following are the activities of the adversary:

- Downloading and installing malicious software such as backdoors
- Gaining remote access to the target system
- Leveraging various methods to keep backdoor hidden and running
- Maintaining access to the target system

Command and Control

The adversary creates a command-and-control channel, which establishes two-way communication between the victim's system and adversary-controlled server to communicate and pass data back and forth. The adversaries implement techniques such as encryption to hide the presence of such channels. Using this channel, the adversary performs remote exploitation on the target system or network.

The following are the activities of the adversary:

- Establishing a two-way communication channel between the victim's system and the adversary-controlled server
- Leveraging channels such as web traffic, email communication, and DNS messages.
- Applying privilege escalation techniques o Hiding any evidence of compromise using techniques such as encryption

Actions on Objectives

The adversary controls the victim's system from a remote location and finally accomplishes their intended goals. The adversary gains access to confidential data, disrupts the services or network, or destroys the operational capability of the target by gaining access to its network and compromising more systems. Also, the adversary may use this as a launching point to perform other attacks.

Tactics, Techniques, and Procedures (TTPs)

The term Tactics, Techniques, and Procedures (TTPs) refers to the **patterns of activities and methods** associated with specific threat actors or groups of threat actors

Tactics

- "Tactics" are the guidelines that describe the **way an attacker performs the attack** from beginning to the end
- This guideline consists of the various **tactics for information gathering** to perform initial exploitation, privilege escalation, and lateral movement, and to deploy measures for persistent access to the system and other purposes

Techniques

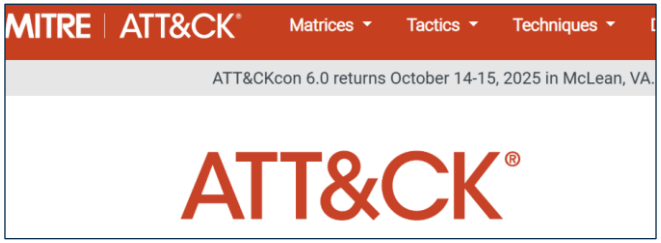
- "Techniques" are the **technical methods used by an attacker** to achieve intermediate results during the attack
- These techniques include **initial exploitation**, setting up and maintaining **command and control channels**, accessing the target infrastructure, covering the tracks of data exfiltration, and others

Procedures

- "Procedures" are **organizational approaches that threat actors follow** to launch an attack
- The number of **actions usually differs** depending on the objectives of the procedure and threat actor group

Tactics, Techniques, and Procedures (TTPs)

- Tactics
  - **What attacker wants to achieve**
- Techniques
  - **How the attacker achieves the goal**
- Procedures
  - **Step-by-step Execution**



Category	Example in a Ransomware Attack
Tactic 🎯	Financial Gain (Holding Data for Ransom)
Technique 🛠️	Phishing Email to Deliver Malware
Procedure 📜	1. Attacker sends a fake email with a malicious attachment. 2. Victim opens the attachment, triggering malware. 3. Malware encrypts files and demands payment.

3. Hacking Concepts

1. Information Security Overview
2. Cyber Kill Chain Concepts
3. Hacking Concepts
4. Ethical Hacking Concepts
5. Information Security Controls

What is Hacking?

- Hacking refers to **exploiting system vulnerabilities and compromising security controls** to gain unauthorized or inappropriate access to a system's resources

- It involves **modifying system or application features** to achieve a goal outside of the creator's original purpose

- Hacking can be used to steal and redistribute intellectual property, leading to **business loss**

What is Hacker?

01

An intelligent individual with **excellent computer skills** who can create and explore computer software and hardware

02

For some hackers, **hacking is a hobby** to see how many computers or networks they can compromise

03

Some hackers' intentions can either be to gain knowledge or to **probe and do illegal things**

Some hack with **malicious intent** such as to steal business data, credit card information, social security numbers, email passwords, and other sensitive data

Hacker Classes

01

Black Hats

Individuals with extraordinary computing skills; they resort to malicious or destructive activities and are also known as crackers

02

White Hats

Individuals who use their professed hacking skills for defensive purposes and are also known as security analysts. They have permission from the system owner

03

Gray Hats

Individuals who work both offensively and defensively at various times

04

Suicide Hackers

Individuals who aim to bring down the critical infrastructure for a "cause" and are not worried about facing jail terms or any other kind of punishment

05

Script Kiddies

An unskilled hacker who compromises a system by running scripts, tools, and software that were developed by real hackers

06

Cyber Terrorists

Individuals with wide range of skills who are motivated by religious or political beliefs to create fear through the large-scale disruption of computer networks

07

State-Sponsored Hackers

Individuals employed by the government to penetrate and gain top-secret information from and do damage to the information systems of other governments

08

Hacktivist

Individuals who promote a political agenda by hacking, especially by defacing or disabling websites

Hacking Phases

In general, there are five phases of hacking:

1. Reconnaissance
2. Scanning
3. Gaining Access
4. Maintaining Access
5. Clearing Tracks

Phase 1: Reconnaissance

- Reconnaissance refers to the preparatory phase where an **attacker seeks to gather information** about a target prior to launching an attack
- This information could be the future point of return, noted for ease of entry for an attack, when more about the **target is known on a broad scale**
- The reconnaissance **target range** may include the target organization's clients, employees, operations, network, and systems

Reconnaissance Types

Passive Reconnaissance

- Passive reconnaissance involves acquiring information **without directly interacting with the target**
- For example, searching public records or news releases

Active Reconnaissance

- Active reconnaissance involves **directly interacting with the target by any means**
- For example, telephone calls to the target's help desk or technical department

Phase 2: Scanning

Pre-attack Phase	Scanning refers to the pre-attack phase when the attacker **scans the network** for specific information based on information gathered during reconnaissance
Port Scanner	Scanning can include the use of dialers, **port scanners**, network mappers, ping tools, and vulnerability scanners
Extract Information	Attackers extract information such as **live machines**, port, port status, OS details, device type, and **system uptime** to launch attack

Phase 3: Gaining Access

1. Gaining access refers to the point where the attacker obtains access to the **operating system or applications** on the target computer or network

2. The attacker can gain access at the **operating system**, **application**, or **network levels**

3. The attacker can **escalate privileges** to obtain complete control of the system. In this process, the target's connected intermediate systems are also compromised

4. Examples include **password cracking**, buffer overflows, denial of service, and **session hijacking**

Phase 4: Maintaining Access

1. Maintaining access refers to the phase when the attacker tries to retain their **ownership of the system**

2. Attackers may prevent the system from being owned by other attackers by securing their exclusive access with **backdoors**, **rootkits**, or **trojans**

3. Attackers can upload, download, or **manipulate data**, applications, and configurations on the **owned system**

4. Attackers use the compromised system to **launch further attacks**

Phase 5: Clearing Tracks

1

Clearing tracks refers to the activities carried out by an attacker to **hide malicious acts**

2

The attacker's intentions include obtaining **continuing access** to the victim's system, remaining **unnoticed and uncaught**, and deleting evidence that might lead to their prosecution

3

The attacker overwrites the server, system, and application logs to **avoid suspicion**

Attackers always cover their tracks to hide their identity

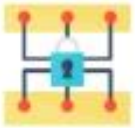
4. Ethical Hacking Concepts

1. Information Security Overview
2. Cyber Kill Chain Concepts
3. Hacking Concepts
4. Ethical Hacking Concepts
5. Information Security Controls

What is Ethical Hacking?

- Ethical hacking involves the use of hacking tools, tricks, and techniques to **identify vulnerabilities** and ensure system security

- It focuses on simulating the techniques used by attackers to **verify the existence of exploitable vulnerabilities** in a system's security



- Ethical hackers perform security assessments for an organization **with the permission of concerned authorities**

Why EH is necessary?

To beat a hacker, you need to think like one!

Ethical hacking is necessary as it **allows for counter attacks against malicious hackers** through anticipating the methods used to break into the system

Reasons why organizations recruit ethical hackers

- To **prevent hackers** from gaining access to the organization's information systems
- To **uncover vulnerabilities** in systems and explore their potential as a security risk
- To analyze and **strengthen an organization's security posture**, including policies, network protection infrastructure, and end-user practices
- To provide adequate preventive measures in order to **avoid security breaches**
- To help **safeguard customer data**
- To **enhance security awareness** at all levels in a business

Ethical Hackers Try to Answer the Following Questions

1. What can an intruder see on the **target system**? (Reconnaissance and Scanning phases)
2. What can an **intruder do** with that information? (Gaining Access and Maintaining Access phases)
3. Does anyone at the target organization **notice the intruders' attempts** or successes? (Reconnaissance and Covering Tracks phases)
4. Are all **components of the information system** adequately protected, updated, and patched?
5. How much time, effort, and money are required to obtain **adequate protection**?
6. Are the **information security measures** in compliance with legal and industry standards?

Skills of EH

1 Technical Skills

- In-depth **knowledge of major operating environments** such as Windows, Unix, Linux, and Macintosh
- In-depth **knowledge of networking** concepts, technologies, and related hardware and software
- A **computer expert** adept at technical domains
- **Knowledgeable about security areas** and related issues
- **"High technical" knowledge** for launching sophisticated attacks

2 Non-Technical Skills

- The **ability to learn** and adopt new technologies quickly
- **Strong work ethics** and good problem solving and communication skills
- Committed to the **organization's security policies**
- An awareness of **local standards and laws**

5. Information Security Controls

1. Information Security Overview
2. Cyber Kill Chain Concepts
3. Hacking Concepts
4. Ethical Hacking Concepts
5. Information Security Controls

Why it is important?

- Information security **controls prevent the occurrence of unwanted events** and **reduce risk** to the organization's information assets.

- The basic security concepts critical to information on the Internet are **confidentiality, integrity, and availability**; the **concepts related to the persons accessing the information** are **authentication**, **authorization**, and **non-repudiation**.

- Information is the greatest asset of an organization. It must be secured using various policies, creating awareness, employing security mechanisms, or by other means.

- This section deals with Information Assurance (IA), defense-in-depth, risk management, cyber threat intelligence, threat modeling, incident management, and AI and ML concepts.

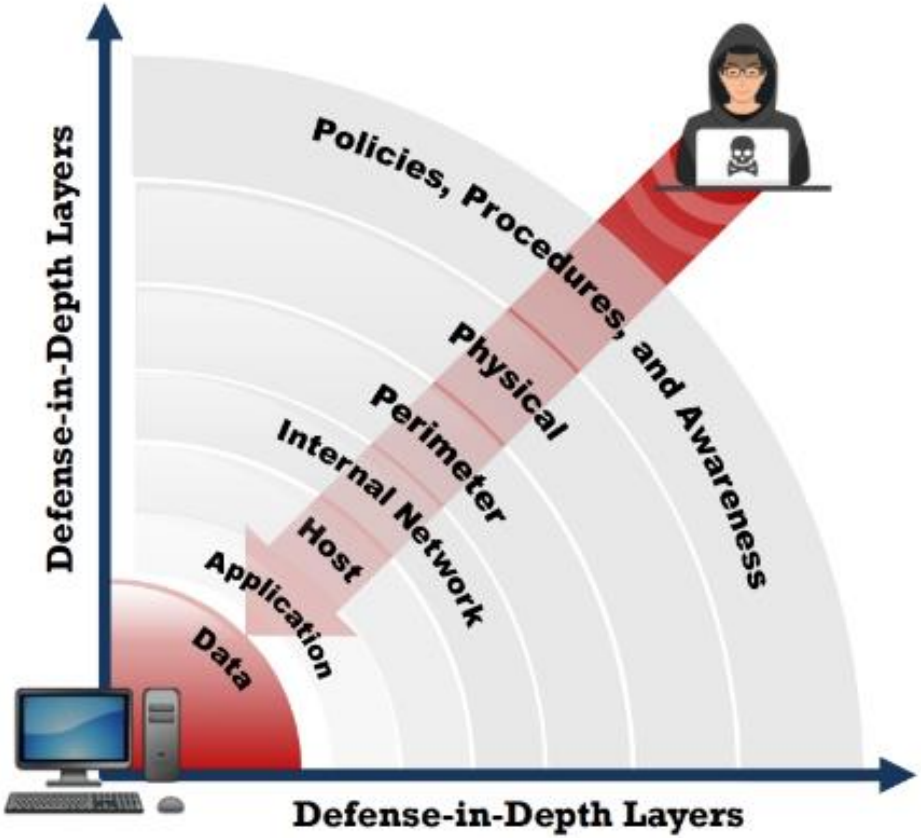
Information Assurance (IA)

- IA refers to the assurance that the **integrity**, **availability**, **confidentiality**, and **authenticity** of information and information systems is protected during the usage, processing, storage, and transmission of information
- Some of the processes that help in achieving information assurance include:

1. **Developing local policy, process, and guidance**
2. **Designing network and user authentication strategies**
3. **Identifying network vulnerabilities and threats**
4. **Identifying problem and resource requirements**
5. **Creating plans for identified resource requirements**
6. **Applying appropriate information assurance controls**
7. **Performing certification and accreditation**
8. **Providing information assurance training**

Defense-in-Depth

- Defense-in-depth is a security strategy in which **several protection layers** are placed throughout an information system
- It helps to **prevent direct attacks** against the system and its data because a break in one layer only leads the attacker to the next layer



What is Risk?

- Risk refers to the degree of **uncertainty** or expectation that an adverse event may cause damage to the system
- Risks are categorized into different levels according to their estimated impact on the system
- A risk matrix is used to scale risk by considering the **probability**, **likelihood**, and **consequence or impact** of the risk

Risk Levels

Risk Level	Action
Extreme or High	➢ Immediate measures should be taken to combat risk ➢ Identify and impose controls to reduce risk to a reasonably low level
Medium	➢ No urgent action is required ➢ Implement controls as soon as possible to reduce risk to a reasonably low level
Low	➢ Take preventive steps to mitigate the effects of risk

Risk Matrix

Probability		Consequences				
		Insignificant	Minor	Moderate	Major	Severe
81 - 100%	Very High Probability	Low	Medium	High	Extreme	Extreme
61 - 80%	High Probability	Low	Medium	High	High	Extreme
41 - 60%	Equal Probability	Low	Medium	Medium	High	High
21 - 40%	Low Probability	Low	Low	Medium	Medium	High
1 - 20%	Very Low Probability	Low	Low	Medium	Medium	High

Likelihood

Note: This is an example of a risk matrix. Organizations need to create their own risk matrix based on their business needs

- Likelihood: The chance of the risk occurring
- Consequence: The severity of a risk event that occurs

Risk Management

- Risk management is the process of **reducing and maintaining risk at an acceptable level** by means of a well-defined and actively employed security program

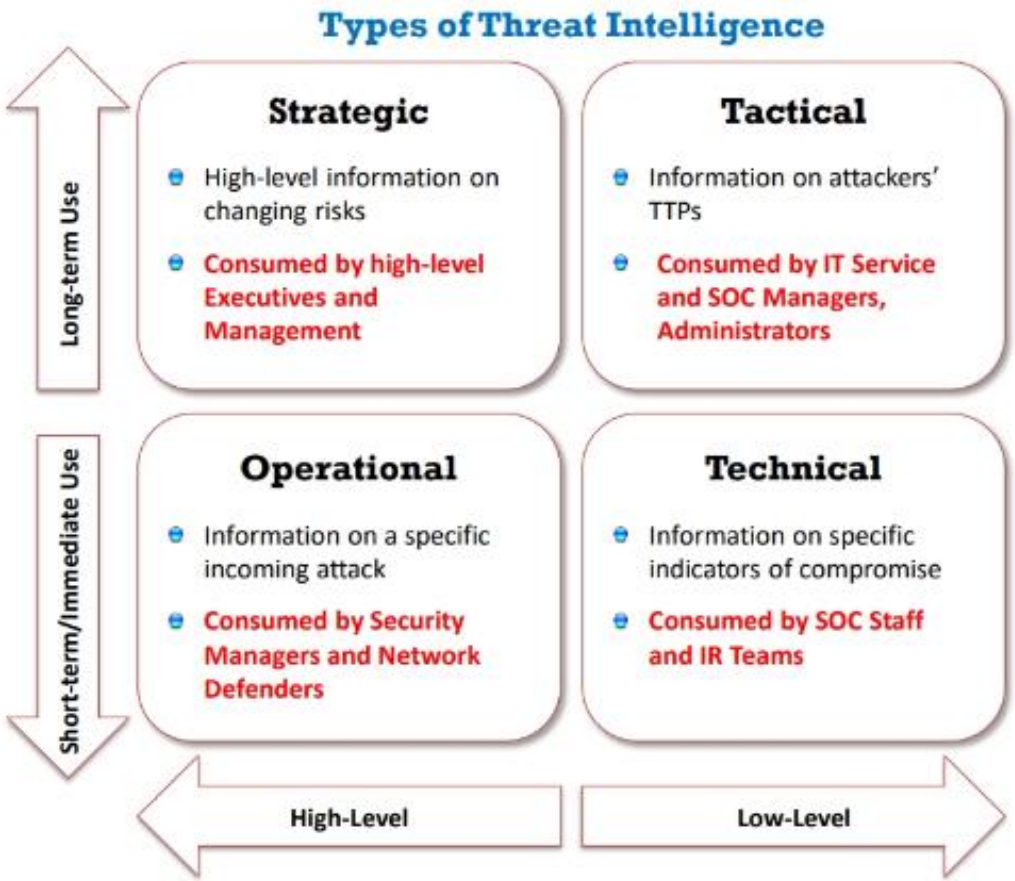
Risk Management Phases

Risk Identification	**Identifies the sources**, causes, consequences, and other details of the internal and external risks affecting the security of the organization
Risk Assessment	**Assesses the organization's risk** and provides an estimate of the likelihood and impact of the risk
Risk Treatment	**Selects and implements appropriate controls** for the identified risks
Risk Tracking	**Ensures appropriate controls are implemented** to handle known risks and calculates the chances of a new risk occurring
Risk Review	**Evaluates the performance** of the implemented risk management strategies

Cyber Threat Intelligence

- Cyber Threat Intelligence (CTI) is defined as the **collection and analysis of information** about threats and adversaries and the drawing of patterns that provide the ability to make knowledgeable decisions for preparedness, prevention, and response actions against various cyber-attacks

- Cyber threat intelligence helps the organization to **identify and mitigate various business risks** by converting unknown threats into known threats; it helps in implementing various advanced and proactive defense strategies



Types of Threat Intelligence

- Describes threats and guides organizations in making various business decisions.
- Extracted from a huge collection of sources and information.
- Four types differ in terms of data collection, data analysis, and intelligence consumption.

Strategic

Purpose: Helps organization align cybersecurity strategies with potential risks.

E.g: A report detailing emerging threats like ransomware and their impact on specific industries

A country-specific analysis showing that a nation-state is targeting critical infras through cyber-espionage

Tactical

Purpose: Assists security teams in implementing defenses such as firewall, IDS/IPS & SIEM rules.

E.g: Details on a phising campaign's characteristics, such as email subject lines, malicious URL and fake login pages.

IoCs like known IP addresses, hashes of malware samples or domain names used by attackers

Operational

Purpose: Provides insights into ongoing attacks or imminent threats, enabling rapid responses.

e.g: Real-time alerts from a threat intelligence platform about DDoS attack targeting the organization's servers.

Information from the dark web indicating that credentials of employees from organization are being sold

Technical

Purpose: Used by security tools and teams for detection and blocking of threats.

E.g: A signature or hash of a specific malware sample shared in a time-sharing community like VirusTotal.

A list of domains or IP addresses used in C2 comm for a botnet.

Threat Modelling

Threat modeling is a **risk assessment approach** for analyzing the security of an application by capturing, organizing, and analyzing all the information that affects the security of an application

Threat Modeling Process

01	Identify Security Objectives	Helps to determine how much **effort needs to be put** toward subsequent steps
02	Application Overview	Identify the **components**, **data flows**, and trust boundaries
03	Decompose the Application	Helps to find more relevant and more **detailed threats**
04	Identify Threats	Identify threats relevant to the **control** scenario and context using the information obtained in steps 2 and 3
05	Identify Vulnerabilities	**Identify weaknesses** related to the threats found using **vulnerability categories**

* Further reading activities

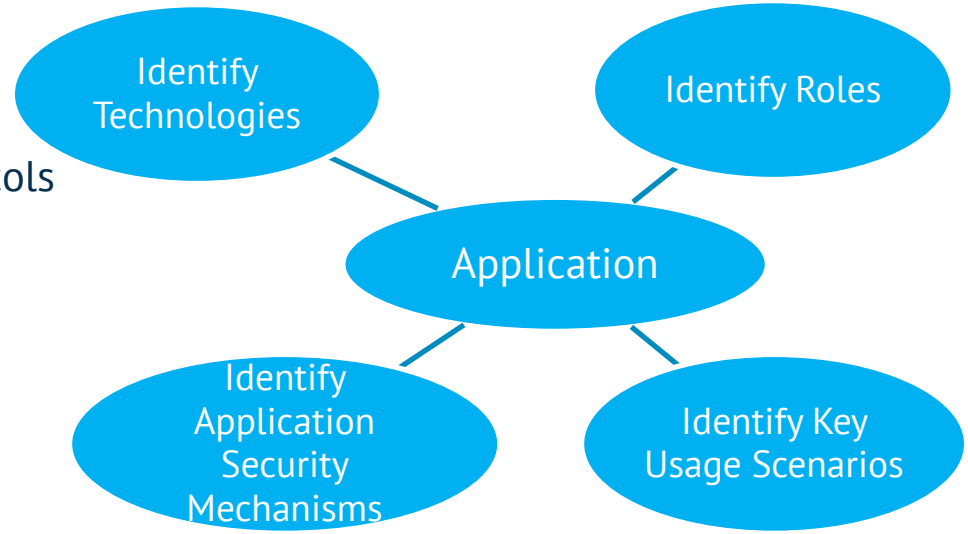
1. Identify Security Objectives

- Security objectives are the goals and constraints related to the application's confidentiality, integrity, and availability.
- Security-specific objectives guide the threat modeling efforts and help to determine how much effort needs to be put toward subsequent steps. To identify security objectives, administrators should ask the following questions:
    - o What data should be protected?
    - o Are there any compliance requirements?
    - o Are there specific quality-of-service requirements?
    - o Are there intangible assets to protect?

* Further reading activities

2. Application Overview

- Identify the components, data flows, and trust boundaries. To draw the end-to-end deployment scenario, the administrator should use a whiteboard.
- First, they should draw a rough diagram that explains the workings and structure of the application, its subsystems, and its deployment characteristics.
- The deployment diagram should contain the following:
    - o End-to-end deployment topology
    - o Logical layers
    - o Key components
    - o Key services
    - o Communication ports and protocols
    - o Identities
    - o External dependencies



* Further reading activities

3. Decompose the Application

- In this step, the administrator breaks down the application to identify the trust boundaries, data flows, entry points, and exit points.
- Doing so makes it considerably easier to find more relevant and more detailed threats and vulnerabilities.

4. Identify Threats

- The administrator should identify threats relevant to the control scenario and context using the information obtained in the application overview and decompose application steps.
- They should bring members of the development and test teams together to identify potential threats.
- The team should start with a list of common threats grouped by their application vulnerability category.
- This step uses a question-driven approach to help identify threats.

* Further reading activities

5. Identify Vulnerabilities

- A vulnerability is a weakness in an application (deployed in an information system) that allows attacker exploitation, thereby leading to security breaches.
- Security administrators should identify any weaknesses related to the threats found using the vulnerability categories to identifying vulnerabilities and fix them beforehand to keep intruders away.

Incident Handling & Response

- Incident handling and response (IH&R) is the **process of taking organized and careful steps** when reacting to a security incident or cyberattack

Steps involved in the IH&R process:

1. **Preparation**
2. **Incident Recording and Assignment**
3. **Incident Triage**
4. **Notification**
5. **Containment**
6. **Evidence Gathering and Forensic Analysis**
7. **Eradication**
8. **Recovery**
9. **Post-Incident Activities**
   - Incident Documentation
   - Incident Impact Assessment
   - Review and Revise Policies
   - Close the Investigation
   - Incident Disclosure

Steps in IH & R Process

Step 1: Preparation

The preparation phase includes performing an audit of resources and assets to determine the purpose of security and **define the rules, policies, and procedures** that drive the IH&R process. It also includes building and training an incident response team, defining incident readiness procedures, and gathering required tools as well as training the employees to secure their systems and accounts.

Step 2: Incident Recording and Assignment

In this phase, the initial reporting and recording of the incident take place. This phase handles identifying an incident and defining **proper incident communication plans** for the employees and also includes communication methods that involve informing IT support personnel or submitting an appropriate ticket.

Step 3: Incident Triage

In this phase, the identified security incidents are **analyzed, validated, categorized, and prioritized**. The IH&R team further analyzes the compromised device to find incident details such as the type of attack, its **severity, target, impact, and method of propagation, and any vulnerabilities it exploited.**

Steps in IH & R Process (cont.)

Step 4: Notification

In the notification phase, the IH&R team **informs various stakeholders**, including management, third-party vendors, and clients, about the identified incident.

Step 5: Containment

This phase helps to **prevent the spread of infection** to other organizational assets, preventing additional damage.

Step 6: Evidence Gathering and Forensic Analysis

In this phase, the IH&R team **accumulates all possible evidence** related to the incident and submits it to the forensic department for investigation. Forensic analysis of an incident reveals details such as the method of attack, vulnerabilities exploited, security mechanisms averted, network devices infected, and applications compromised.

Step 7: Eradication

In the eradication phase, the IH&R team **removes or eliminates the root cause** of the incident and closes all the attack vectors to prevent similar incidents in the future.

Steps in IH & R Process (cont.)

Step 8: Recovery

After eliminating the causes for the incidents, the IH&R team **restores the affected** systems, services, resources, and data through recovery. It is the responsibility of the incident response team to ensure that that the incident causes no disruption to the services or business of the organization.

Step 9: Post-Incident Activities

Once the process is complete, the security incident requires additional review and analysis before closing the matter. Conducting a final review is an important step in the IH&R process that includes:

- Incident documentation
- Incident impact assessment
- Reviewing and revising policies
- Closing the investigation
- Incident disclosure

Quick Review Question

- What is CIA in security?
- What are the different types of hackers?
- Explain the different attack phases?

Summary of Main Teaching Points

1. This chapter discussed elements of information security, and information security attacks.
2. It discussed cyber kill chain methodology, TTPs, and IoCs in detail
3. It also discussed hacking concepts, types, and phases
4. This chapter also covered ethical hacking concepts such as the scope and limitations of ethical hacking, skills, and other pertinent information in detail
5. It discussed information security controls such as defense-in-depth, risk management, cyber threat intelligence, threat modeling and incident management process

Question and Answer Session

Q & A

What we will cover next

The next module will go into detail about how attackers, as well as ethical hackers and pen testers, perform **footprinting** to **collect information** about the target of an evaluation before an attack or audit.